

Open EDR – Supply Chain Vulnerability Report

Report Date: July 10, 2026
Researcher: Eneshan Erdoğan Karaca
GitHub: [Kisaca-Enes](#)
Status: Full Disclosure

1. Summary

The Open EDR (Xcitem / Comodo) project has **not updated its bundled third-party libraries for 7–8 years**. These libraries contain **12 directly identifiable** and **over 100 indirect CVEs**, including **Remote Code Execution (RCE)**, **Information Disclosure**, **Denial of Service (DoS)**, and **Security Bypass** vulnerabilities.

The vendor (Xcitem/Comodo) was notified on **June 21, 2026**. On **June 23**, a one-sentence reply was received: *"We will update."* Since then, **4 follow-up emails** have been sent – all **ignored**. This report is published after the **responsible disclosure** period to inform the public.

2. What is a Supply Chain Attack?

A supply chain attack targets a software product through its **external dependencies** rather than its own code. If a Python project uses a vulnerable library, that project becomes vulnerable too. Similarly, Open EDR relies on libraries like **cURL**, **OpenSSL**, **Boost**, and **AWS SDK** – any known vulnerability in these directly affects Open EDR.

This creates a **0-day vector** for **APT groups** and **cyber attackers**. Instead of attacking the target directly, adversaries can exploit a **weak dependency** to gain access. This is a **stealthy** attack vector that often bypasses firewalls and monitoring systems.

Example: A company uses software from vendor X. Vendor X uses an outdated, vulnerable OpenSSL. An attacker exploits that OpenSSL flaw to breach vendor X's software, then pivots into the company's network. This is a **supply chain attack**.

3. Affected Components & Vulnerabilities

The table below lists **12 directly identified** vulnerabilities (classified as **Vuln-001** through **Vuln-012**) found in Open EDR's bundled libraries.

ID	Library	Version	Related CVE	Impact
Vuln-001	AWS SDK C++	1.7.63	CVE-2025-14760	Data Integrity Violation
Vuln-002	Boost	1.70.0	CVE-2023-52323	Heap Overflow – RCE
Vuln-003	cURL	7.63.0	CVE-2019-3822	Stack Overflow – RCE
Vuln-004	cURL	7.63.0	CVE-2018-16890	Information Disclosure
Vuln-005	cURL	7.63.0	CVE-2021-22890	MITM Attack
Vuln-006	OpenSSL	1.1.1b	CVE-2026-41676	Buffer Overflow – RCE
Vuln-007	OpenSSL	1.1.1b	CVE-2019-1543	Nonce Reuse – Info Leak
Vuln-008	OpenSSL	1.1.1b	CVE-2023-0215	Use-After-Free – RCE/DoS
Vuln-009	OpenSSL	1.1.1b	CVE-2023-0286	Type Confusion – Info Leak
Vuln-010	OpenSSL	1.1.1b	CVE-2022-0778	Infinite Loop – DoS

Vuln-011	OpenSSL	1.1.1b	CVE-2023-0464	Resource Exhaustion – DoS
Vuln-012	OpenSSL	1.1.1b	CVE-2023-0465	Security Bypass

⚠ In total, 12 direct CVEs and 100+ indirect CVEs exist in these outdated versions. RCE vulnerabilities are especially critical because the EDR runs with **SYSTEM** privileges.

4. Repository References (Evidence)

The following links provide **direct evidence** of the vulnerable library versions used in Open EDR.

- **AWS SDK C++ (1.7.63):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/awssdkcpp/CHANGELOG.md>
- **Boost (1.70.0):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/boost/boost/version.hpp>
- **cURL (7.63.0):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/curl/RELEASE-NOTES>
- **OpenSSL (1.1.1b):**
<https://github.com/ComodoSecurity/openedr/blob/main/edrav2/epri/openssl/openssl/README>

5. Vendor Communication Timeline

- **June 21, 2026** – Initial report sent to security@xcitium.com.
- **June 22, 2026** – Oleg Kalinin (Development Manager CCS) replied with a single sentence: *"We haven't updated for a long time, we will update in the next release."*
- **June 22 – July 10, 2026** – **4 follow-up emails** sent requesting update timeline, CVE assignment, and additional technical details.
- **July 10, 2026 (today)** – **No response** received to any of these follow-up emails.

Note: Xcitium/Comodo has **no official security policy** listed in the repository. There is also no indication whether Open EDR is **actively maintained** or **deprecated**. This creates uncertainty and risk for both users and researchers.

6. Comodo's Historical Pattern of Negligence

Comodo has a track record of **ignoring security researchers**. Two notable examples:

- **2016 – Google Project Zero:** Researchers disclosed a Comodo vulnerability after **12 days**. Comodo responded by claiming they "follow responsible disclosure" but had **no actual policy** in place.
- **2017 – Marcus Hutchins (MalwareTech):** The researcher reported a vulnerability (ComoDoS) to Comodo multiple times, received **no response**, and was forced to disclose publicly.

These examples show a **systematic disregard** for security researchers. The current case follows the same pattern.

7. Technical Assessment

All vulnerabilities were identified using **Occam's Razor** – the simplest method: reviewing **README**, **CHANGELOG**, and **version** files. No **fuzzing**, **debugging**, or **exploit development** was performed.

This demonstrates how **easily** supply chain vulnerabilities can be discovered. Attackers can use the same approach to find **critical flaws** in seconds.

Recommendation: Developers should **regularly audit** their dependencies and keep them **up-to-date**. They should also establish a **clear security policy** to guide researchers.

8. Conclusion & Recommendations

- **For Open EDR users:** Take **immediate defensive measures** – monitor network traffic, restrict EDR communications, and consider alternative EDR solutions.
- **For Xcitium/Comodo:** Update all third-party libraries **urgently**. Create and publish a **formal security policy**. Clearly state the project's maintenance status.
- **For the security community:** Treat this as a case study in **supply chain risk**. Always verify the hygiene of your dependencies – including those used by your security tools.

Critical Takeaway: An EDR that fails to secure its own dependencies cannot be trusted to secure anything else. If Open EDR contains **7-year-old libraries with 100+ CVEs**, it poses a **direct risk** to every environment where it is deployed.

Disclaimer: This report is published after a **30-day responsible disclosure period** and **4 follow-up emails** with **no meaningful response** from the vendor. The purpose is to **inform users** and **improve security awareness** in the open-source ecosystem.

© 2026 BoxStrikes Team, Eneshan Erdoğan Karaca – This document may be freely shared and referenced with attribution.